

For financial institutions and service providers with complex retail payment operations, business continuity plans should enable restoration of service within timeframes that are reasonable for internal business units, other dependent financial institutions, and counterparties. Financial institutions providing significant card issuing, merchant processing, EFT/POS, ACH, and retail payment-related Internet banking services should also test these plans periodically with customer financial institutions and counterparties to ensure plans are sufficient.

Vendor and Third-Party Management

Action Summary

Financial institutions should establish and maintain effective vendor and third-party management programs because of the increasing reliance on nonbank providers. Financial institutions must understand the complex nature of arrangements with outside parties and ensure adequate due diligence for the engagement of the relationships and ongoing monitoring.

Some financial institutions rely on third-party service providers and other financial institutions to provide retail payment system products and services to their customers. Many retail payment services are directly related to core processing financial institution operations (e.g., accessing demand deposit accounts through the use of financial institution-issued bankcards) and may be run in-house through the use of purchased turnkey systems. However, financial institutions outsource many retail payment-related services to third parties, including foreign-based, either to enhance the services performed in-house or to offer new retail payment services that are otherwise not cost effective.

To ensure retail payment operations are conducted appropriately, financial institutions should have comprehensive contract provisions and adequate due diligence processes. They should also monitor service providers for compliance with contracts and service level agreements. Effective monitoring should include the review of select retail payment transaction items to ensure they are accurate and processed timely. The integrity and accuracy of retail payment transactions posted to customer accounts depend on the use of proper control procedures throughout all phases of processing, including outsourced functions.

Regardless of whether the financial institution's control procedures are manual or automated, internal controls should address the areas of transaction initiation, data entry, computer processing, and distribution of output reports. These control considerations apply to processing checks, including through RDC, as well as electronically created payment orders, electronic bankcard, debit card, and ACH transactions. Financial institutions must also maintain effective control over service provider access to customer and financial institution information consistent with GLBA section 501(b). Contractual

provisions should define the terms of acceptable access and potential liabilities in the event of fraud or processing errors.^[47]

Retail Payment Instrument Specific Risk Management Controls

Action Summary

Specific retail payment instruments introduce risks that require effective internal controls and adherence to the relevant clearing house, association, interchange, and regulatory requirements. Financial institutions should address these risks in their information security and business continuity planning programs

Checks

Financial institutions manage the risk exposure to check payment processing by establishing appropriate account opening and monitoring controls. Account opening controls that incorporate information from credit bureau services may mitigate credit risk exposure to criminals and to customers with a history of financial problems. Such screening is also the basis for customer verification in support of BSA/AML compliance and for qualifying customers for RDC. Institutions should perform a credit assessment of those customers for whom they collect large dollar volumes of checks.

Financial institutions use a variety of monitoring tools during check processing as a means of identifying potential fraudulent activity or for early detection of kiting. These automated tools are typically available from major vendors. Institutions should monitor the payment activity of their customers and take appropriate action when credit limits are exceeded or when their business practices may indicate possible fraud or money laundering activity. Institutions that offer commercial customers services for RDC should make such arrangements under contracts that clearly state the liability of the commercial customer in the event of a dispute over the imaged checks.

Regulation CC requires that when a paying financial institution decides to return a check of \$2,500 or more, it must provide a notice of nonpayment to the depository financial institution, in which the check was deposited, to mitigate the depository institution's financial loss in case the customer tries to withdraw funds represented by the returned check. Regulation CC also requires a check to be returned to the depository financial institution expeditiously, regardless of the amount. A paying bank returns a check expeditiously if it returns the check to the depository bank within two business days of presentment (for local checks) or four business days (for nonlocal checks). Alternatively, a bank returns a check expeditiously if it sends the check in the same manner as it (or a similarly situated bank) would have sent the check for forward collection.

Using ECP for payment can reduce risks to depository financial institutions because it permits them to deliver check data to paying financial institutions more quickly than by presenting paper checks. The shorter delivery time permits paying financial institutions to (1) identify checks that cannot be paid and (2) notify the depository financial institution

about those returned checks using an electronic return notice and up to one day earlier than would occur with the physical exchange of paper checks.

Check truncation (the conversion of MICR information to electronic form), on the other hand, introduces the risk of unauthorized changes to converted check information in transmission or in storage. As with RDC, this risk may increase when truncation occurs at the customer location. Financial institutions should develop and implement appropriate information processing safeguards to mitigate this risk. These safeguards should include logical access controls and separation of duties to minimize potential tampering with electronically converted check information and images during processing, and to ensure the MICR and check image databases are protected from unauthorized access. Check truncation also introduces the risk that a customer's account may be debited twice for the same check. This happens either when the MICR data is read, the account is debited, and the check is accidentally sent to the proof/sorter where it is read again and the account is debited a second time or when an electronic check file is inadvertently duplicated. Financial institutions should develop preventive controls to avert checks from being read twice or electronic check files from being duplicated or processed twice, and they should have detective controls to determine whether debits arise from the same check. These controls should also be applied to processes where checks are converted to ACH debits.

Check fraud is a significant factor in losses reported by financial institutions. The leading form of check fraud is check kiting; that is, presenting checks to two or more financial institutions for the purpose of fraudulently obtaining interest-free unauthorized loans. Other types of check fraud include forged, altered, and counterfeit checks. "Positive pay" is a technique that can reduce check fraud by requesting businesses to send electronic files of information to the financial institution on all checks the business has issued. The financial institution compares this information against electronic information regarding checks presented for payment. If a check presented for payment is not included in the positive-pay information, the institution requests the corporation to make a pay/no pay decision.

ACH

ACH operations pose a variety of risks including credit, liquidity, and operational. NACHA and the two national ACH operators (the Reserve Banks and EPN) have clear expectations that financial institutions will manage these risks, particularly when the institutions engage in riskier ACH activities. In recent years, the ACH operators have begun to offer a variety of risk management tools to help control ACH risks. Financial institutions should employ those tools that are commensurate with the risks taken.

The risk of fraud can be mitigated through proper due diligence for all originating customers and strict adherence to ACH and credit policies. Additional mitigation can be achieved by avoiding high risk businesses and customers. Limits should be appropriate for the risks of each customer and the use of pre-funding arrangements or reserves can be effective in controlling losses. Management should review monitoring reports offered by the ACH operators that can assist in early detection of unauthorized ACH transactions.

For ACH credit entries, a financial institution that serves as the ODFI incurs credit risk upon initiating the entries until its customer funds the account. The ODFI is responsible for settling payments originated using its routing number even if the transactions are outsourced to third-party service providers. The RDFI incurs credit risk when it grants

funds availability to its customer prior to the final settlement of the credit entry. For ACH debit entries, the ODFI incurs credit risk from the time it grants funds availability to the originator (usually on the settlement day) until the ACH debit can no longer be returned by the RDFI. If the transaction is properly authorized, returns must be made no later than the second banking day following settlement. If not authorized properly, the financial institution exposure can be up to 60 days from when it sends a periodic statement to the consumer. An ODFI will normally charge back a returned ACH debit to the originator. However, the ODFI may suffer a loss if the originating account has insufficient funds, is closed, or is frozen because of bankruptcy or other legal action.

To manage its credit exposures, an ODFI should establish policies, procedures, and limits that acknowledge the risks certain businesses and customers bring to an ACH operation. Higher risk businesses include gambling and adult entertainment firms. The financial institution's policies should clearly state the types of businesses and customers that are acceptable and should treat all ACH customers as unsecured borrowers that are subject to the institution's standard credit review and approval process. An ODFI should conduct thorough due diligence of its originating customers, including understanding the nature of their businesses and financial condition. For certain customers, pre-funding or reserve arrangements may be necessary to control the risk. On an ongoing basis, an ODFI (and its service providers) should monitor the creditworthiness of its customers, and establish and periodically review ACH exposure limits for them. In addition, an ODFI should implement procedures to monitor ACH entries relative to the originator's exposure limit across multiple settlement dates. Breaches in limits should be reported to the appropriate levels of management. An ODFI should monitor and research frequently the returns, particularly unauthorized returns. The Federal Reserve and EPN can provide such reports to ODFIs.

An RDFI should establish prudent overdraft and funds availability policies and practices to mitigate its credit exposures. Credit risk, with respect to a debit entry, arises if the RDFI allows the debit to overdraw its customer's account. When a financial institution fails to comply with the NACHA rules, it exposes itself to contractual liability and fines. In addition, Regulation E applies to electronic fund transfers, including ACH transactions. The notice, authorization, error resolution, and timing requirements of Regulation E are of particular importance. Noncompliance with Regulation E exposes a financial institution to litigation and civil money penalties. Financial institutions should also monitor their compliance with applicable BSA and OFAC requirements concerning unusual transactions and transactions involving blocked parties.

Financial institutions should understand the impact that ACH transaction risk has on their liquidity. For example, an ODFI may not be able to settle (collect) an ACH debit, or an RDFI may not be able to settle an ACH credit because of fraud, service disruption, or the default of an ACH Network participant. This could impair the financial institution's ability to meet its obligations and result in losses. Financial institutions should consider the volume of their uncollected ACH transactions as part of their liquidity risk management practices. For certain customers, pre-funding arrangements may be used to reduce liquidity risk.

Given the highly automated nature of ACH activities, operational risks should be managed closely. Clear policies and procedures should establish the proper control environment. Exceptions and operational problems, including processing delays and customer complaints, should be monitored in a timely manner. Management and staff should be familiar with NACHA rules and the requirements of the Reserve Banks and EPN. Well conceived and tested contingency plans are vital given the time sensitive nature of ACH transactions. Higher expectations for BSA compliance require additional

attention from management. Audits should be performed on a frequent basis by qualified auditors.

Third-Party ACH Processing

While a financial institution's responsibilities do not change with the use of a technology service provider for ACH processing, its risk exposure may increase as a result of the servicer's direct access to an ACH operator. A TSP may transmit ACH transactions directly to an ACH operator using the ODFI routing number. However, it is the ODFI that warrants the validity of each entry transmitted by the service provider, including the basic requirement that a receiver has authorized all entries. To reduce risk to all parties, the financial institution should establish controls over TSP operations, and the ODFI should maintain control over its settlement accounts. ^[48]

Although the federal regulators do not enforce the NACHA rules, a financial institution subject to them should have appropriate risk-management and control processes to ensure compliance with these rules. For example, NACHA requires TSPs performing ACH processing functions on behalf of an ODFI or RDFI to conduct an annual compliance audit covering the requirements of their rules. The financial institution should review and assess all audits of its service provider's internal controls. NACHA rules also require the ODFI to have contractual agreements with third-party senders specifying that the third-party sender is in compliance with NACHA rules and applicable laws and regulations. NACHA rules further require the ODFI to have an agreement with a TSP that has direct access to an ACH operator. NACHA specifies that the agreement sets out the rights and responsibilities of all parties, including:

- A requirement that the third-party service provider obtain the prior approval of the ODFI before originating ACH transactions for originators under the ODFI routing number. ODFI approval of each originator should be contingent upon the creditworthiness of the originator and the execution of an originator and ODFI agreement.
- ODFI dollar limits for files that a TSP deposits with the ACH operator. The service provider should notify the ODFI of any file exceeding established dollar limits before depositing the file at the ACH operator so that the ODFI can either approve it as an exception or hold it until the next business day.
- A provision that restricts the TSP's ability to initiate corrections to files already transmitted to the ACH operator. The ODFI should restrict correction capability. If the TSP has the ability to make file corrections, the ODFI should authorize and approve any changes to the file totals before the ACH operator releases the file for processing. ^[49]
- A requirement that a third-party sender who enters into an agreement with an ODFI establish the identity of each originator using commercially reasonable methods, warrant that the originators will assume their responsibilities under NACHA rules, and warrant that it will assume the liabilities of the ODFI. ^[50] The lack of a direct relationship between the ODFI and the originator poses a risk to the ODFI. The ODFI should conduct proper due diligence, establish exposure limits, and employ other monitoring procedures to ensure that the business practices of the third-party sender and its merchant clients do not create an undue risk to the ODFI. The ODFI

should be able to substantiate that the third-party sender has sufficient creditworthiness to back the warranties it makes relative to the risk, nature, and volume of ACH transactions; the underlying originators; and the exposure duration.

NACHA also requires participating financial institutions to conduct annual audits of their ACH operations to assess compliance with NACHA rules. These audits can provide examiners with insights into the quality of ACH operations.

Risk Considerations for Business Banking EFT Payments

Financial institutions that offer corporate customers access to Web-based business banking applications to facilitate the direct origination of payments (e.g., ACH credits/debits, wire transfers, etc.) create special risk considerations for the financial institution and its corporate customers. These applications offer corporate customers an efficient way to conduct treasury management activities such as invoice payments and funds transfers. However, these features also increase the velocity in which errors and fraud can subject businesses or the bank to loss and can be the target of malicious software designed to circumvent online authentication methods to obtain credentials that can be used to initiate fraudulent payments.

Ongoing education of corporate customers remains one of the best ways financial institutions can mitigate the risks associated with online business banking applications. This is especially the case for some small businesses and community-based corporate entities (e.g., churches, schools, etc.) where the awareness of payments fraud techniques may be limited and the impact of a fraud can be significant. In addition to providing a secure environment for corporate payments (e.g., strong encryption, transaction risk profiling, etc.), financial institutions can help mitigate corporate payments risk by ensuring their corporate customers understand the importance of good business practices such as payment origination dual controls, daily account reconciliation, and other measures to protect the integrity of the corporate customers computer systems (e.g., virus protection, operating system upgrades, etc.).

Credit Cards

Credit and fraud losses are two of the most significant credit card-related risks to a financial institution. Credit losses due to contractual delinquency and bankruptcy account for the majority of credit card charge-offs. Fraud includes unauthorized use of lost or stolen cards, fraudulent applications, counterfeit or altered cards, and the unauthorized use of a cardholder's credit card number for card-not-present transactions.

Consumer compliance regulations (Regulation Z and Regulation E) and association operating rules (Visa and MasterCard) provide significant consumer protection for fraudulent transactions. According to Regulation E, if cardholders report timely the loss of their credit cards, they are responsible for no more than \$50 of the charges resulting from fraud. Regulation Z provides additional billing error resolution procedures. Visa, MasterCard, Discover, and American Express have zero liability programs, which indemnify card holders for all fraudulent losses in many circumstances. The issuing financial institution or the merchant pays the costs of any fraud involving credit cards. At a minimum, the merchant should obtain an authorization, a cardholder's signature, or an electronic imprint of the card (electronic information on the card) at the POS. The merchant is required by the card companies to cover fraudulent transactions through the

chargeback process if it does not follow the minimum procedures. This has become a significant issue for many online retailers processing card-not-present transactions. The major bankcard companies; however, have introduced services to reduce the liability of the merchants. Under one initiative, issuers will assume losses for fraudulent transactions if the payment was authorized using the bankcard company's authentication procedures.

A control method financial institutions use to reduce risk is the authorization process to approve the credit transaction. For example, when the merchant swipes the bankcard, the issuer can deny authorization of the transaction if the consumer is over his or her credit limit, is delinquent, or if the card has been reported as stolen. Financial institutions can also employ the address verification service (AVS) to verify a cardholder's billing address and other pertinent information. AVS is used for mail, telephone, and Internet transactions.

Employing the appropriate underwriting, account management, monitoring, and collection practices can mitigate credit risk. By setting standards that reduce the probability of delinquency and fraud, financial institutions can more effectively control credit losses.

Debit/ATM Cards

A significant risk with PIN or signature-based debit or ATM cards is that unauthorized individuals will obtain them and make fraudulent transactions. Financial institutions and their technology service providers should mitigate these risks by executing financial institution-merchant and financial institution-customer contracts that delineate each party's liabilities and responsibilities. Institutions should also establish adequate physical safeguards including the installation of surveillance cameras and access/entry control devices. State and federal laws, particularly Regulation E, protect consumers by limiting their liability if they give notice of lost or stolen cards, or of unauthorized EFTs within a specified period.

ATM stand-in arrangements, which enable EFT/POS networks to authorize transactions if a card issuer or processor is unable to authorize and process transactions, also increase the potential for fraud since normal credit limit and authorization procedures are not in effect. Stand-in authorization arrangements should include reasonable credit limits and defined terms of duration to limit potential financial loss.

Card/PIN Issuance

Financial institutions also assume certain fraud-related risks when issuing credit, debit, and ATM cards either in-house or under contract to third parties. Inadequate internal controls or ineffective card and PIN issuance procedures may result in fraudulent customer transactions. Inappropriate separation of duties that allow employees access to both customer account and PIN information exposes the institution to potential employee fraud.

Embossing and encoding blank plastic card stock, if conducted in-house, should be performed in a secure area and include inventory controls, accounting controls for the number of cards used (including test and reject cards), and dual controls for blank card stock storage. Procedures for the interim storage and accounting of card stock should

exist for all cards not under dual control. Adequate controls should also exist for captured cards (cards confiscated by an ATM machine or elsewhere).

Accountability controls should also be established to ensure all cards initially disbursed from the storage area are either delivered to the mail area or destroyed. Returned cards should be handled by a function independent of the mail department. Control cards should be mailed randomly to customers and their delivery should be validated within a few days to ensure that no theft has taken place.

PIN generation should be done at the time of card issuance. Active PIN information should be controlled, including encrypting the information on storage devices. Access to PIN databases should be restricted on a need-to-know basis. Staff access to PIN information should be reviewed periodically to confirm controls are current and working effectively.

The PIN should not appear in printed form, and staff members should not be able to retrieve or display a customer PIN online. PIN mailers should be processed and delivered with the same level of security used for mailing cards, and an active PIN should never be included with the card mailed to a customer.

The PIN should not be transmitted unencrypted, and the PIN system should record the number of unsuccessful PIN entries, restricting access to a customer's account after a limited number of attempts. If a customer forgets the PIN, he or she should select a new one rather than having staff retrieve the old one.

For institutions that outsource these functions to service providers, written agreements should define roles and responsibilities and detail control and problem resolution procedures. Effective vendor management should include a periodic review of service providers control environments and relevant internal and external audit reports.

Merchant Acquiring

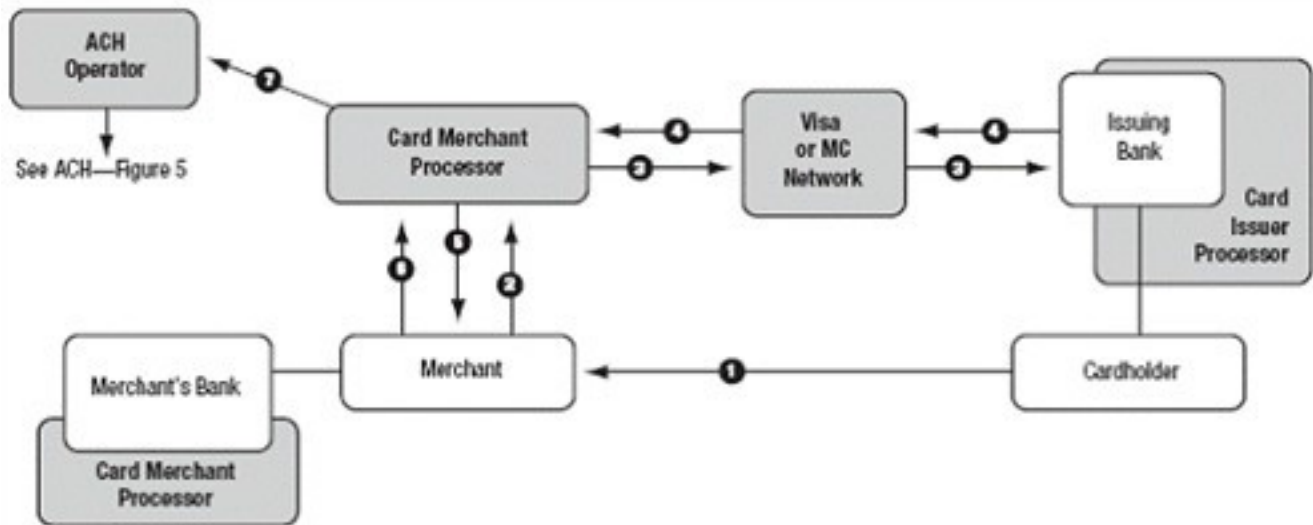
Basic credit card processing participants include the cardholder, cardholder's issuing bank, merchant, merchant's acquiring ^[51] bank, and the credit card association (e.g., Visa, MasterCard, Discover, AMEX, Diners Club).

Merchants wanting to accept card association-branded credit card sales payments must be sponsored by an acquiring bank that is a member of the credit card association. Merchants may maintain a settlement account with their acquiring bank, or settle via ACH transactions between the acquiring bank and the merchant's bank. Acquiring banks typically do not process their merchants' transactions directly so this function may be outsourced to a third-party service provider (merchant acquirer) that performs the data processing functions of authorization and clearing and settlement. Some merchant banks may also engage the services of an ISO or Member Service Provider (MSP) to solicit and sign up merchants and merchant transaction processing services. Regardless of the presence of such third parties, the credit card networks expect the acquiring bank to be the risk-controlling entity throughout the credit card process. This section will address risks from the acquiring bank's perspective.

The credit card transaction process is initiated when the consumer or merchant swipes the customer's credit card through a POS terminal. The credit approval and payment transaction processing is the same for card-not-present (mail order, telephone order, Internet sales) as they are for card-present transactions. Card-not-present retailers have

additional authentication requirements. The terminal reads and electronically transmits the card number, purchase amount, and merchant ID via the appropriate credit card association network. The credit card association forwards the electronic transaction to the issuing bank or its designated processor to verify that the account is valid and that the customer has adequate credit to cover the purchase. The issuing bank responds back through the network with either an authorization or rejection. Once the merchant receives acknowledgement through the POS terminal, the sale is completed or rejected.

Generally, at the end of each business day, a merchant sends his or her daily charge activity in batch form to his or her acquiring bank or its designated processor who forwards the transaction information to respective credit card associations for clearing. Individual transactions are sent to the issuing banks for customer account processing and debiting of the cardholder's account. Settlement occurs through the card association with the transfer of funds from the issuing banks to the respective merchant's bank. The merchant's acquiring bank posts a credit of the net sales proceeds less interchange and charge-backs to the individual merchant account.



Authorization

1. A consumer uses a credit card to pay a merchant.
2. The merchant sends the encrypted transaction data to a card merchant processor (e.g., First Data Merchant Services) for authorization.
3. The card merchant processor sends the transaction data to the consumer's (issuing) bank over the Visa or MasterCard network. The issuing bank is a licensed member of Visa or MasterCard and holds agreements with, and issues cards to, consumers.
4. The issuing bank authorizes the amount and issues an authorization code or declines the transaction.
5. The card merchant processor notifies the merchant that the transaction either has been authorized or declined. The merchant requests the consumer's signature as authorization for the transaction or notifies the consumer that the transaction has been declined.

Processing

6. Once authorized, the transaction must be "captured" by the merchant. The capture uses information from the successful authorization to charge the authorized amount of money to the consumer's credit card. The merchant accumulates captures and credits into a batch, which then will be settled as a group. The merchant submits the batch to the card merchant processor to finalize the transactions. (If the consumer returns goods after a transaction has been captured, a "credit" is generated.)

Settlement

7. The card merchant processor receives the information and settles the batch, then sends ACH items through the ACH operator to the issuing and merchant banks. (See Figure 5; the merchant bank is the ODFI, with the card merchant processor serving as authorized sending point.) The operator settles transactions between the issuing and merchant banks. The merchant bank credits the merchant's account.

Note: Many merchant banks hire a third party (acquiring processor) for bankcard processing. The processor provides credit card processing, billing, reporting and settlement, and operational services to the merchant bank.

Figure 12: Diagram of typical credit card transaction ^[52]

As Figure 12 shows, the credit card process is a technology-driven payments process. The payment process relies almost exclusively on the effective application and monitoring of strong technology standards and practices to protect transactional data integrity and to mitigate operational risks across the entire payments network.

Operational and data integrity risks can arise from improper processing of bankcard